



Transformación Digital
Agencia de Transformación Digital y Telecomunicaciones

Dirección General de Ciberseguridad

Checklist de cumplimiento obligatorio IDOR

febrero 2026



Check de cumplimiento obligatorio

La dependencia deberá completar, compartir con la ATDT y conservar en su documentación, el siguiente check de cumplimiento por cada sistema, aplicación o API.

A. Control de acceso

- ☐ Cada recurso valida autorización a nivel de objeto.
- ☐ El acceso no depende únicamente de que la sesión esté autenticada.
- ☐ No es posible acceder a recursos de terceros modificando identificadores.

B. Identificadores

- ☐ Los identificadores directos (id, user_id, document_id, etc.) están protegidos por validación de pertenencia.
- ☐ El uso de UUID, hashes u otros identificadores no sustituye la autorización.
- ☐ No existen identificadores predecibles o reutilizables.

C. APIs y endpoints

- ☐ Todos los métodos HTTP (GET, POST, PUT, PATCH, DELETE) aplican controles de autorización.
- ☐ No existen versiones antiguas de la API con controles relajados.
- ☐ El cambio de formato (.json, .xml, .csv, .pdf) no altera el control de acceso.

D. Flujos secundarios

- ☐ Endpoints de registro, recuperación, notificaciones o exportación no exponen recursos ajenos.
- ☐ No existen IDOR ciegos (acciones sin respuesta directa con impacto posterior).

E. Operación y monitoreo

- ☐ Se implementa rate limiting en endpoints sensibles.
- ☐ Se registran intentos de acceso a recursos no autorizados.
- ☐ Existen alertas por patrones de enumeración o acceso anómalo.

Evidencia requerida

Como evidencia de cumplimiento deberá entregarse, según aplique:

- Descripción técnica de los controles implementados.
- Diagramas de flujo o lógica de autorización.
- Resultados de pruebas de seguridad (internas o de terceros).
- Evidencia de monitoreo o registros de eventos.



A. Control de acceso

A1. Cada recurso valida autorización a nivel de objeto

Ejemplo de cumplimiento:

Al solicitar un expediente ([/api/expedientes/{id}](#)), el sistema valida en el backend que el expediente **pertenece a la persona usuaria autenticada** o que esta cuenta con un rol explícito que le autoriza el acceso (por ejemplo, servidor público asignado al trámite).

Ejemplo de incumplimiento:

El sistema devuelve el expediente únicamente porque el usuario está autenticado, sin verificar la relación usuario-recurso.

Evidencia esperada:

Lógica de autorización documentada, diagramas o reglas de negocio.

A2. El acceso no depende únicamente de que la sesión esté autenticada

Ejemplo de cumplimiento:

Un usuario autenticado intenta acceder a un recurso de otra persona y el sistema responde **403 Forbidden**, aun cuando la sesión sea válida.

Ejemplo de incumplimiento:

Cualquier usuario autenticado puede consultar cualquier recurso existente.

Evidencia esperada:

Pruebas negativas documentadas (acceso denegado a recursos ajenos).

A3. No es posible acceder a recursos de terceros modificando identificadores

Ejemplo de cumplimiento:

Cambiar manualmente un [id](#) en la URL o cuerpo de la solicitud **no devuelve información distinta** a la autorizada.

Ejemplo de incumplimiento:

Modificar [document_id=123](#) por [document_id=124](#) permite acceder a información de otra persona.

Evidencia esperada:

Resultados de pruebas de manipulación de parámetros.

A4. Se realizan pruebas negativas de autorización (IDOR testing)

Ejemplo de cumplimiento:

Se ejecutan pruebas modificando manualmente identificadores (id, folio, UUID, etc.) y el sistema rechaza el acceso a recursos de terceros con códigos 401/403.

Ejemplo de incumplimiento:

No se realizan pruebas de manipulación de identificadores o las solicitudes alteradas continúan devolviendo información de otros usuarios.

Evidencia esperada:

Resultados de pruebas de seguridad, bitácoras de validación, capturas de solicitudes/respuestas o reporte técnico de pruebas de autorización.



B. Identificadores

B1. Identificadores directos protegidos por validación de pertenencia

Ejemplo de cumplimiento:

El sistema puede utilizar identificadores directos (por ejemplo: id, user_id, folio, object_id), siempre que el acceso al recurso esté condicionado a una validación explícita de pertenencia entre el objeto solicitado y el usuario autenticado.

Cada solicitud que referencia un objeto mediante un identificador directo valida que dicho objeto pertenezca al usuario autenticado o que este tenga permisos explícitos sobre él.

Ejemplo de incumplimiento:

El sistema permite acceder a un recurso únicamente conociendo o modificando el identificador (id, user_id, folio), sin validar la relación con el usuario autenticado.

Evidencia esperada:

Reglas de validación de pertenencia (modelo de autorización).

B2. UUID, hashes u otros identificadores no sustituyen la autorización

Ejemplo de cumplimiento:

Un UUID válido no devuelve información si el usuario no tiene autorización sobre el recurso.

Ejemplo de incumplimiento:

El sistema confía en que el UUID “no es adivinable” y no valida autorización.

Evidencia esperada:

Pruebas donde UUID válidos no autorizados son rechazados.

B3. No existen identificadores predecibles o reutilizables

Ejemplo de cumplimiento:

Los identificadores no siguen secuencias simples ni se reutilizan entre recursos o personas usuarias.

Ejemplo de incumplimiento:

IDs consecutivos (1001, 1002, 1003) permiten la enumeración de recursos.

Evidencia esperada:

Descripción del esquema de generación de identificadores.



C. APIs y endpoints

C1. Todos los métodos HTTP aplican controles de autorización

Ejemplo de cumplimiento:

GET, PUT, PATCH y DELETE validan autorización de la misma forma sobre el recurso.

Ejemplo de incumplimiento:

GET valida autorización, pero PUT o DELETE no lo hacen.

Evidencia esperada:

Matriz de endpoints y métodos con controles aplicados.

C2. No existen versiones antiguas con controles relajados

Ejemplo de cumplimiento:

Las versiones antiguas están deshabilitadas o mantienen los mismos controles que la versión actual.

Ejemplo de incumplimiento:

[/api/v1/](#) permite acceso sin validación mientras [/api/v2/](#) sí la implementa.

Evidencia esperada:

Inventario de versiones activas y su estado.

C3. El cambio de formato no altera el control de acceso

Ejemplo de cumplimiento:

Solicitar un recurso en [.json](#), [.csv](#) o [.pdf](#) produce el mismo control de autorización.

Ejemplo de incumplimiento:

El formato [.csv](#) permite descargar información sin validar permisos.

Evidencia esperada:

Pruebas de acceso por formato.

C4. La autorización se aplica de forma centralizada y consistente

Ejemplo de cumplimiento:

Todos los endpoints validan la autorización mediante un mecanismo común (middleware, filtro, interceptor o componente compartido), asegurando reglas homogéneas para cada solicitud independientemente del método HTTP o versión de la API.

Ejemplo de incumplimiento:

Cada endpoint implementa validaciones de autorización de forma manual o parcial, generando inconsistencias donde algunas rutas aplican controles y otras permiten acceso sin verificación adecuada.

Evidencia esperada:

Arquitectura o diseño técnico del mecanismo centralizado de autorización, configuración de middleware/filtros, o documentación del componente reutilizable implementado.



D. Flujos secundarios

D1. Endpoints secundarios no exponen recursos ajenos

Ejemplo de cumplimiento:

Los endpoints de exportación, notificación o recuperación solo operan sobre recursos autorizados.

Ejemplo de incumplimiento:

Un endpoint de exportación permite descargar información de otros usuarios.

Evidencia esperada:

Revisión de flujos no principales.

D2. No existen IDOR ciegos

Ejemplo de cumplimiento:

Acciones como envío de correos o generación de archivos solo afectan recursos autorizados.

Ejemplo de incumplimiento:

Un usuario puede provocar acciones sobre recursos de terceros sin recibir respuesta directa.

Evidencia esperada:

Pruebas funcionales y revisión de impactos secundarios.



E. Operación y monitoreo

E1. Rate limiting en endpoints sensibles

Ejemplo de cumplimiento:

Los endpoints críticos limitan la cantidad de solicitudes por usuario o IP.

Ejemplo de incumplimiento:

Un usuario puede realizar miles de solicitudes sin restricción.

Evidencia esperada:

Configuración de rate limiting o WAF.

E2. Registro de accesos no autorizados

Ejemplo de cumplimiento:

Los intentos fallidos de acceso a recursos ajenos quedan registrados en logs.

Ejemplo de incumplimiento:

Los accesos no autorizados no generan registros.

Evidencia esperada:

Extractos de logs o políticas de registro.

E3. Alertas por enumeración o acceso anómalo

Ejemplo de cumplimiento:

El sistema genera alertas cuando una identidad accede a múltiples recursos distintos en poco tiempo.

Ejemplo de incumplimiento:

No existe detección de patrones anómalos.

Evidencia esperada:

Reglas de monitoreo, SIEM o reportes de alertas.

E4. Se cuenta con procedimiento de rotación de credenciales ante riesgos de exposición

Ejemplo de cumplimiento:

Se dispone de mecanismos para rotar contraseñas, tokens, llaves de API o sesiones activas cuando se identifiquen vulnerabilidades o riesgos de acceso indebido.

Ejemplo de incumplimiento:

No existen procedimientos o capacidades técnicas para invalidar credenciales activas.

Evidencia esperada:

Procedimiento documentado o registros de rotación.



F. Superficie de exposición

F1. Existe inventario de sistemas/APIs expuestos a Internet

Ejemplo de cumplimiento:

Se mantiene un inventario actualizado de aplicaciones, APIs, versiones y endpoints publicados a Internet, incluyendo responsable, finalidad y estado operativo.

Ejemplo de incumplimiento:

Se desconocen los servicios o versiones que permanecen expuestos públicamente o existen endpoints sin registro formal.

Evidencia esperada:

Inventario de activos, listado de servicios expuestos, escaneo de superficie externa o documentación de arquitectura.

F2. Servicios no necesarios fueron retirados, deshabilitados o aislados

Ejemplo de cumplimiento:

Los sistemas heredados, versiones antiguas o servicios sin requerimiento operativo externo fueron despublicados, deshabilitados o aislados de Internet.

Ejemplo de incumplimiento:

Aplicaciones antiguas o APIs obsoletas continúan accesibles públicamente sin justificación operativa ni controles modernos de autorización.

Evidencia esperada:

Configuraciones de firewall/WAF, reglas de red, actas de retiro o capturas que demuestren la no exposición.

F3. Servicios restringen su acceso exclusivamente a servicios o redes autorizadas

Ejemplo de cumplimiento:

Los servicios sólo son accesibles desde redes o sistemas explícitamente autorizados mediante segmentación de red, VPN, ACL, allowlists u otros mecanismos equivalentes, evitando su acceso directo desde Internet.

Ejemplo de incumplimiento:

APIs o aplicaciones destinadas a uso interno pueden ser accedidas públicamente desde Internet o desde orígenes no autorizados, sin restricciones de red o filtrado de acceso.

Evidencia esperada:

Diagramas de red, reglas de firewall/ACL, configuraciones de acceso, listas de orígenes permitidos o pruebas de conectividad que demuestren la restricción.